NERDY DOCUMENTS

How the FBS Boise Store Map works behind the scenes, and every lock on the doors.

THE SHORT VERSION

- Nothing on the site can be seen without signing in, not even the pictures.
- We keep as little as possible: a first name, a username, and the maps. **No phone numbers, no email addresses, no home addresses.**
- Passwords and codes are never stored as typed. Only scrambled versions (hashes) are kept, so nobody can read them, not even the admin.
- Every request is checked: who you are, whether you're allowed, and whether it really came from this site.
- Too many wrong guesses and the door shuts for 15 minutes.

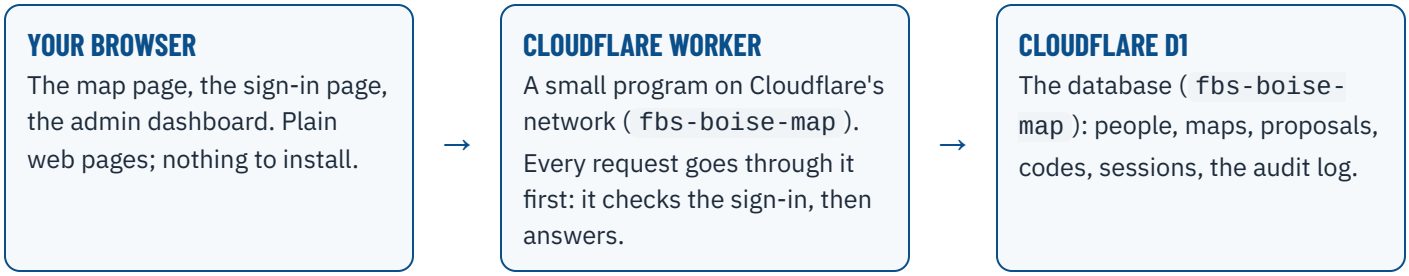
FBS Boise Store Map · Nerdy Documents · October 2026. Written from the site's code as it is on this date. No secret values are in this document.

WHAT'S INSIDE

1. The big picture
2. What we store (and what we never store)
3. Signing in
4. Who can see and change what
5. Checks on every single request
6. Rate limits (stopping guessers)
7. On your phone or computer
8. Secrets
9. Audit log and housekeeping
10. How it's tested
11. Known limits (the honest part)
12. If something goes wrong
13. Glossary

> This is the technical write-up. You don't need any of it to use the site: the Planning Guide covers that. It's here so anyone can check how their information is handled.

1. THE BIG PICTURE



- **Static files** (pages, scripts, the 3D store, photos) live with the Worker, but the Worker runs *before* any file is handed out (`run_worker_first`), so files are locked too.
- **Public without signing in**: only the sign-in page and what it needs to show (its script and styles, the logo, fonts, `robots.txt`). Everything else answers “sign in” (pages are redirected to `/login`).
- **The admin area** (`/admin/` and every other spelling of it) is only for admins. Anyone else gets the same plain “page doesn't exist” page, so a member can't even tell the dashboard is there.
- **Publishing**: a change merged into the `main` branch on GitHub is deployed automatically by Cloudflare Workers Builds. Database changes are applied by hand, on purpose, before the merge.
- **Preview copies** of the site get no database and no secrets.

2. WHAT WE STORE

KEPT	WHAT'S IN IT
People	First name, username, role (member or admin), status, dates (joined, last visit). The password is stored only as a salted, peppered hash (page 3).
Maps	Each person's floor plans: departments, shelves, notes. The owner, a version number, dates.
Master map history	Every version of the real layout, who made it, and which proposal it came from (by first name).
Proposals	Plans sent for review, with the notes written on them.
Access codes	A hash of each code (for checking it) plus an encrypted copy, so the admin can see codes nobody has used yet. Used codes are never shown again.
Reset codes	Only a hash. The code is shown to the admin once and never again.
Sessions	Only a hash of each sign-in token, its dates, and the browser's name (cut to 160 characters).
Rate-limit counters	Counts under a scrambled key. The IP address itself is never stored.
Audit log	What happened, when, and which account did it (page 9). No passwords, no codes.

WHAT WE NEVER STORE

- **Phone numbers.** The site no longer asks for them. A cleanup step (`migrations/0006_forget_phones.sql`) permanently wipes the ones the old sign-up saved. Nothing in the code reads those columns any more, and automated tests check that no response ever contains a phone number.
- **Email addresses, home addresses, birthdays, photos of people.** None of these are asked for.
- **Passwords as typed**, **codes as typed** (except the admin's encrypted copy of unused access codes), **sign-in tokens as issued.**
- **IP addresses.** They are only used, scrambled, as rate-limit keys.

> **What the team can see about each other:** the first name of whoever made a map or a master version. Usernames, sign-in times and map counts are only on the admin dashboard.

3. SIGNING IN

PIECE	HOW IT WORKS
Access code	8 characters like `ABCD-EF23`, from a 31-character alphabet with no look-alikes (no I, L, O, 0, 1), made with the system's secure random generator (no bias). **Works once.** At most 5 usable at a time; a new set cancels the unused ones. Two people racing on one code: exactly one gets it (a single database update decides).
Profile	With the code you pick a username (3 to 40 letters, numbers, dots, dashes, underscores; unique, ignoring capitals) and a password (10 to 200 characters). Nothing is used up until everything checks out.
Passwords	PBKDF2-SHA256 with 100,000 rounds and a random 16-byte salt per person, then mixed with a secret “pepper” (HMAC-SHA256) that lives only in Cloudflare's secret store. A stolen copy of the database alone isn't enough to test guesses.
Checking a password	Always does the full work, even for a username that doesn't exist, and compares in constant time, so the answer takes the same time either way. Every failure says the same thing: “That username and password don't match.”
Sessions	Signing in gives the browser a random 32-byte token in a cookie named `__Host-fbs_s`: **Secure** (HTTPS only), **HttpOnly** (page scripts can't read it), **SameSite=Strict** (other sites can't use it). Only its SHA-256 hash is stored. It ends after 30 days without a visit, and after 90 days at most.
Every request	The session is looked up together with the person. Removed or demoted? It counts on the very next request.
Sign out	Deletes the session on the server and clears the cookie. An old copy of the cookie stops working.
Forgot password	The admin makes a reset code for that one person: one use, 7 days, a new one cancels the last. Using it sets a new password and signs that person out everywhere else. Their maps are untouched.
Admin password	Reset only with a one-time setup code made by whoever runs the Cloudflare account (72 hours, one use). It signs the admin out everywhere. Changing the password from the dashboard signs out the admin's other devices.
Second admin	Only the first admin (the **owner**) can make or remove admins. The owner can't be demoted or reset by anyone else. Only someone who already has a username and password can be made an admin.

4. WHO CAN SEE AND CHANGE WHAT

THING	RULE
Your maps	Only you can change them. Others can open them only when the admin switches on “share everyone's maps” (read-only). Anyone else gets “not found”, so they can't even tell a map exists.
The master map	Everyone signed in can see it. Only admins can change it, and only while it isn't locked. Every save checks it's based on the newest version, so two people can't overwrite each other (the second gets asked to reload).
Proposals	Seen only by the person who sent it and the admins. Only admins decide.
Admin tools	Codes, people, resets, settings, the master history and the Advisor settings: admins only, checked on the server for every request, not just hidden on the page.
Limits per person	Up to 30 maps; each map up to 1,500 items and 400 KB; notes up to 500 characters.

5. CHECKS ON EVERY SINGLE REQUEST

- **Forged-request protection (CSRF).** Every change needs a special header (`X-FBS: 1`) that other websites can't add. If the browser says where the request came from (Origin, Sec-Fetch-Site), it must be this site.
- **Content Security Policy.** The browser is told to run only this site's own scripts, styles, fonts and images: `default-src 'self'; script-src 'self'; style-src 'self'; img-src 'self' data: blob:; object-src 'none'; base-uri 'none'; frame-ancestors 'none'; form-action 'self'`. No inline code anywhere, and an automated check fails the build if any appears.
- **Other headers:** HTTPS only for a year (HSTS), no MIME sniffing, can't be put in a frame (stops click-jacking), no referrer sent to other sites, camera/microphone/location/payment/USB turned off, cross-origin isolation, and “don't index” for search engines.
- **Size limits.** Every request body has a size cap (1 KB for a code check up to 460 KB for a map), checked before and while reading. Only a JSON object is accepted.
- **Input rules.** Names: letters, spaces, apostrophes, periods and hyphens, up to 60, invisible characters dropped. Usernames, ids and codes have strict patterns. Anything that doesn't fit is refused with a plain message.
- **Database safety.** Everything people type reaches the database as a bound parameter, never pasted into the query text, so it can't change what a query does.
- **Errors** come back as a short plain message. Internal details and stack traces are never sent to the browser.
- **Caching.** Answers about people or maps are never cached (`no-store`); signed-in files are cached only privately on your device.

6. RATE LIMITS

Counted in the database under a scrambled key (a keyed hash of the IP address, or of the username). A whole IPv6 /64 counts as one place, so changing addresses inside one home or server doesn't help.

WHAT	LIMIT
Wrong codes (check, sign-up, reset)	10 per 15 minutes per place. Only wrong codes and taken usernames count.
Sign-in	10 tries per 15 minutes per place **and** 10 per 15 minutes per username.
Admin setup code	10 per hour per place.
Admin password change	10 per 15 minutes.
Map saves	120 per 10 minutes per person.
New or deleted maps; master changes	60 per 10 minutes per person (each).
Proposals; settings	30 per 10 minutes per person (each).

7. ON YOUR PHONE OR COMPUTER

- Names and notes typed by people are always shown as plain text, never as page code, so nobody can slip a script into a name.
- Unsaved map changes are kept on the device until they're saved. They are wiped when you sign out, when the session ends, and whenever the sign-in page opens, so the next person on a shared computer never sees them.
- The only other thing kept on the device: your light/dark choice and a note that this browser has signed in before (so the page opens on “Sign in”). Nothing personal.
- The map checks every few minutes, and whenever you come back to the tab, that you're still allowed in.
- **Print / share** makes the PDF on your own device. The site doesn't send it anywhere; you choose where it goes.
- The site loads nothing from other websites: no trackers, no ads, no analytics, no outside fonts.

8. SECRETS

- Two secrets live in Cloudflare's secret store, never in the code or on GitHub: **PEPPER** (mixes into every password, code and rate-limit key) and **PHONE_KEY** (an AES-256-GCM key that encrypts the unused access codes; the name is from the phone-number days).
- If either is missing or the wrong shape, the site **stays locked** and says “The site isn't set up yet”: it fails closed, never open.
- Never change or delete them: every password and code depends on them.
- The public health check (`/api/health`) only answers yes/no: database reachable, secrets present, codes table present.

9. AUDIT LOG AND HOUSEKEEPING

Important events are written to an audit log with the time and the account that did them: joining, sign-ins, failed sign-ins (with no account or username attached, so it can't reveal which usernames exist), password resets, new code sets, removals, admin powers given or taken, map and master changes, proposals and settings. It never holds passwords or codes, and entries are deleted after a year.

Old data is cleaned up automatically: expired sessions; reset codes a week after they expire; rate-limit counters after a day; used setup codes after 30 days; cancelled access codes after 90 days; master versions beyond the newest 200.

Removing a person signs them out at once and deletes their maps, proposals, sessions and codes in one step. The master history keeps what was applied but renames them “Removed member”.

10. HOW IT'S TESTED

- **Over 330 automated tests** run against a real local copy of the Worker and database: who can open what, every security header, forged requests, the cookie settings, codes used once, two people racing on one code, session lifetimes, rate limits (including bursts and IPv6), sign-in, reset codes, second admins, removing people, map permissions and sharing, the master lock, and that no response ever carries a phone number.
- **Browser tests** drive real Chromium through sign-up, sign-in and password reset, and fail on any console error or security-policy violation.
- **A code check** fails the build on inline scripts or styles, on links to other sites, and on risky browser functions (`innerHTML` , `eval` and the like).

11. KNOWN LIMITS (THE HONEST PART)

No website can promise that nothing will ever leak. These are the gaps we know about, so they can be weighed and fixed if needed:

- **No two-step sign-in** (no text or app code). A strong, unique password is the main lock. Planned option: an authenticator app for admins.
- **No email or self-service reset.** A forgotten password needs the admin. Members can't change their password themselves yet, except with a reset code.
- **Lock-out by guessing.** Someone who knows a username can lock it for 15 minutes by guessing wrong 10 times. Annoying, not dangerous.
- **Admins are trusted.** An admin can see names and usernames and remove people. A second admin has the same powers as the owner, except making admins and touching the owner.
- **Cloudflare logs.** Worker logs are switched on for troubleshooting. They are kept by Cloudflare under its own retention rules and can include page addresses and error messages.
- **Backups** rely on Cloudflare D1's own recovery (“Time Travel”, which can restore the database to a recent point). There is no separate export schedule.
- **Housekeeping runs with traffic** (there's no timer), so a quiet week delays clean-up a little.
- **Leftover columns** from the first version (work area, an unused attempts counter) are still in the database, empty or unused.
- **The browser has to cooperate**: the cookie and the Content Security Policy depend on a modern browser. Very old browsers get less protection.

12. IF SOMETHING GOES WRONG

IT HAPPENED	DO THIS
Someone left, or a device was lost	Dashboard → **Remove** them (signs them out at once). Or **Reset password** to cut off only the old devices.
A code was sent to the wrong person	**Make a new set of 5**: every unused code stops working. For a reset code, make a new one: the old one stops.
You think a password leaked	Reset it (members: **Reset password**; admin: change it under **Your account**). Both sign out the other devices.
The admin password is lost	Whoever runs the Cloudflare account makes a setup code (`npm run setup-code`) and you set a new one at `/login?setup=1`.
A second admin shouldn't be one	The owner presses **Remove admin powers**. It applies on their very next click.
Data looks wrong or was deleted	Master map: **Review** → **Master history** → **Restore**. Anything else: Cloudflare D1 Time Travel can restore the database to a recent point (whoever runs the Cloudflare account).
You suspect a bug or a break-in	Tell whoever runs the site. Don't post details publicly. See `SECURITY.md` in the code.

13. GLOSSARY

WORD	MEANING
Hash	A one-way scramble. The same input always gives the same output, but you can't turn the output back into the input.
Salt	Random extra data added to each password before hashing, so two people with the same password get different hashes.
Pepper	A secret added to every hash. It's kept away from the database, so a stolen database alone is useless for guessing.
PBKDF2	A deliberately slow password hash: 100,000 rounds make each guess expensive.
HMAC	A hash that needs a secret key; used for codes and rate-limit keys.
AES-GCM	Strong encryption that also detects tampering; used for the admin's copy of unused codes.
Session / cookie	After you sign in, your browser holds a random token (in a cookie) that proves it's you until it expires or you sign out.
CSRF	A trick where another website makes your browser do something on this one. Blocked by the special header and origin checks.
CSP	Content Security Policy: a list the browser enforces of where scripts and styles may come from.
Worker / D1	Cloudflare's server program and database that run the site.

FBS Boise Store Map · Nerdy Documents · October 2026